Activity 4 Report: Database Users, Roles, Privileges and Access Control

COMP 018 Database Administration | Project tested: OJT Management System (Java Swing + PostgreSQL) | Date of testing: 6 November 2026

1. Cover and links

Item	Value
Testing group	G08: Borreta, Joshua; Bola, Martin Lawrence; Juatchon, Joaquin Phillip; Marcos, Karl Raphael; Pacheco Jr., Sancho; Vera Cruz, Euan Joseph
Project tested	OJT Management System
Owning group	[Owning group no. and name]
Repository	[Repository URL of the OJT Management System]
Tracker	https://github.com/EclipseChan/bwisIT-Solutions---Campus-Canteen-Pre-Order-and-Queue-Management-System/tree/main/other_group_tests
Evidence files	a4_access_tests.txt, a3_deploy.txt

2. Access-control plan (from the project SQL)

Five login roles, no group roles, no passwords. Privileges are granted directly to each role: admin manages the users table and reads audit_log; student reads project data and inserts or updates applications, requirements and attendance; academic supervisor reads data and updates only selected columns (requirement review fields, placement status, attendance.is_verified); company supervisor reads and writes attendance and evaluations; coordinator manages companies, company supervisors, applications and placements. No role has DELETE anywhere, because tables use a deleted_at column.

3. Privilege matrix (S select, I insert, U update, D delete)

Table	admin	student	acad. sup.	comp. sup.	coord.
academic_supervisors	----	----	----	----	S---
attendance	----	SIU-	S---	SIU-	S---
audit_log	S---	----	----	----	----
companies	----	S---	----	S---	SIU-
company_supervisors	----	----	----	S---	SIU-
evaluations	----	S---	S---	SIU-	S---
ojt_applications	----	SIU-	S---	----	SIU-
ojt_placements	----	S---	S---	S---	SIU-
requirements	----	S---	S---	----	S---
student_requirements	----	SIU-	S---	----	S---
students	----	S---	S---	S---	S---
users	SIU-	----	----	----	----

4. Verification results

Each test ran as postgres with the session role set to the account under test (SET ROLE through PGOPTIONS), because the roles have no password. Write tests used WHERE false so no data changed.

Role	Test	Expected	Actual
admin	SELECT users / audit_log	Allowed	Allowed (5 rows, 0 rows)
admin	INSERT users (rolled back)	Allowed	Allowed
admin	DELETE users	Denied	Denied
admin	SELECT students	Denied	Denied
student	SELECT users (password_hash)	Denied	Denied
student	SELECT students	Allowed	Allowed
student	UPDATE ojt_applications.status	Not clear from plan	Allowed (whole-table UPDATE grant)
student	UPDATE student_requirements.status and verified_at	Not clear from plan	Allowed
student	UPDATE attendance.is_verified	Not clear from plan	Allowed
student	DELETE attendance	Denied	Denied
student	SELECT company_supervisors	Denied	Denied
academic supervisor	UPDATE student_requirements.status	Allowed	Allowed
academic supervisor	UPDATE student_requirements.file_path	Denied	Denied (column-level grant works)
academic supervisor	UPDATE ojt_placements.start_date	Denied	Denied
academic supervisor	UPDATE ojt_placements.status	Allowed	Allowed
academic supervisor	SELECT companies	Denied	Denied
company supervisor	UPDATE evaluations	Allowed	Allowed
company supervisor	SELECT ojt_applications / users	Denied	Denied
coordinator	UPDATE ojt_placements	Allowed	Allowed
coordinator	UPDATE users	Denied	Denied
coordinator	DELETE companies	Denied	Denied
coordinator	SELECT evaluations	Allowed	Allowed
admin, student	CREATE TABLE, DROP TABLE, CREATE ROLE, CREATE DATABASE	Denied	Denied for all four (permission denied for schema public, must be owner, no CREATEROLE, no CREATEDB)

All roles are non-superuser with no CREATEDB or CREATEROLE. Table owner is postgres. ojt_student has CONNECT on ojt_management but not on canteen_db or postgres.

5. Issues and recommendations

#	Finding	Recommendation
1	The application connects as postgres, so none of these privileges are enforced while the app runs. The README states this	Connect each session with the role that matches the user, or at least use one non-owner runtime role
2	The five roles have no password (rolpassword is null) although the README shows PASSWORD	Set passwords with ALTER ROLE or use group roles plus per-person logins
3	The student role can UPDATE every column of ojt_applications, student_requirements and attendance, so it can approve its own application, verify its own requirement and mark	Replace whole-table UPDATE with column-level grants, as already done for the academic supervisor

	attendance verified	
4	The company supervisor can UPDATE every column of attendance and evaluations. Student, supervisor and coordinator roles can read all students, attendance and evaluations with no row-level security	Add row-level security or views limited to the user's own placement
5	The admin role can insert users but has no access to students, academic_supervisors or company_supervisors, yet the app creates the profile row together with the account	Grant the profile tables to the admin role or create accounts through a function
6	audit_log has 0 rows after account creation, application, approval, verification and evaluation, and the database has no triggers	Add triggers or application code that writes audit entries
7	PUBLIC keeps CONNECT and TEMP on ojt_management (datacl starts with =Tc)	REVOKE ALL ON DATABASE ojt_management FROM PUBLIC
8	Deletes are blocked for every role, which fits the soft-delete columns, but no role can set deleted_at on most tables	Decide which role performs soft deletes and grant that column

6. Feedback to owners

Sent on 6 November 2026: findings 1 to 7. Role privileges matched the plan except where listed.

7. Limitations

Tests used SET ROLE as an administrator, not real logins, because the roles have no password. The application was not run under the ojt_ roles. Application-level tests are in Activity 3.

AI usage declaration

- Tool: Claude (Anthropic).
- Tasks: interpreting the results of the testing.
- Validation: the commands were run by the group on its own server, and every result in this report comes from the saved output files.